

Lab Report: Network Sniffing and Connectivity Diagnosis

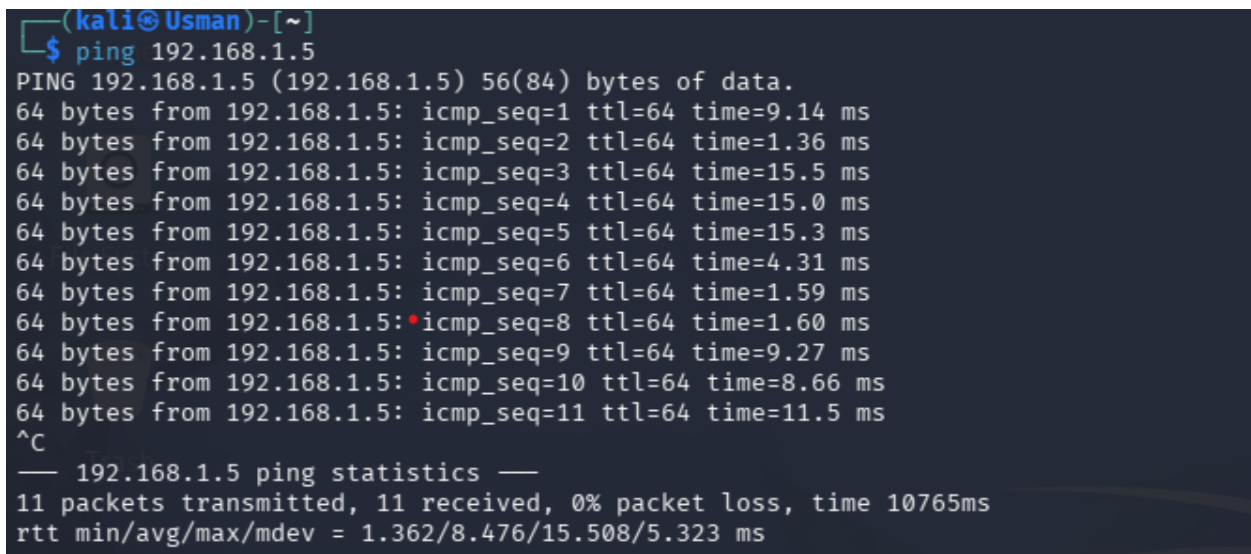
Name: Muhammad Usman Saleem

Environment: Kali Linux (Attacker/Diagnostic) & Metasploitable 2 (Target)

1. Environment Setup & Connectivity

The lab environment was configured using a **Host-Only** network adapter to ensure a controlled testing environment.

- **Kali Linux IP:** 192.168.1.3
- **Metasploitable 2 IP:** 192.168.1.5



```
(kali@Usman)~[~]
$ ping 192.168.1.5
PING 192.168.1.5 (192.168.1.5) 56(84) bytes of data.
64 bytes from 192.168.1.5: icmp_seq=1 ttl=64 time=9.14 ms
64 bytes from 192.168.1.5: icmp_seq=2 ttl=64 time=1.36 ms
64 bytes from 192.168.1.5: icmp_seq=3 ttl=64 time=15.5 ms
64 bytes from 192.168.1.5: icmp_seq=4 ttl=64 time=15.0 ms
64 bytes from 192.168.1.5: icmp_seq=5 ttl=64 time=15.3 ms
64 bytes from 192.168.1.5: icmp_seq=6 ttl=64 time=4.31 ms
64 bytes from 192.168.1.5: icmp_seq=7 ttl=64 time=1.59 ms
64 bytes from 192.168.1.5: icmp_seq=8 ttl=64 time=1.60 ms
64 bytes from 192.168.1.5: icmp_seq=9 ttl=64 time=9.27 ms
64 bytes from 192.168.1.5: icmp_seq=10 ttl=64 time=8.66 ms
64 bytes from 192.168.1.5: icmp_seq=11 ttl=64 time=11.5 ms
^C
— 192.168.1.5 ping statistics —
11 packets transmitted, 11 received, 0% packet loss, time 10765ms
rtt min/avg/max/mdev = 1.362/8.476/15.508/5.323 ms
```

2. Traffic Capture (Wireshark GUI)

Wireshark was initiated on the primary interface (eth0) to monitor real-time packet exchange.

Methodology:

1. Started capture via the Wireshark GUI.
2. Generated ICMP traffic via terminal.
3. Accessed the Metasploitable web server via the Firefox browser.
4. Stopped capture after reaching a sufficient sample size (approx. 2 minutes).

No.	Time	Source	Destination	Protocol	Length	Info
11	10.160842459	192.168.1.3	192.168.1.5	TCP	74	37996 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=1943672814 TSecr=0 WS=256
12	10.172896291	192.168.1.5	192.168.1.3	TCP	74	80 → 37996 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294964199 TSecr=1943672814 WS=128
13	10.172973843	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=1943672826 TSecr=4294964199
14	10.173161638	192.168.1.3	192.168.1.5	HTTP	664	POST /dvwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
15	10.173581644	192.168.1.5	192.168.1.3	TCP	66	80 → 37996 [ACK] Seq=1 Ack=599 Win=7640 Len=0 TSval=4294964199 TSecr=1943672827
16	10.260412176	192.168.1.3	192.168.1.5	HTTP	55	GET /dvwa/index.php HTTP/1.1
19	10.260771768	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=599 Ack=393 Win=64256 Len=0 TSval=1943672914 TSecr=4294964292
20	11.264876814	192.168.1.3	192.168.1.5	HTTP	522	GET /dvwa/index.php HTTP/1.1
21	11.322784914	192.168.1.5	192.168.1.3	TCP	2962	80 → 37996 [ACK] Seq=393 Ack=1055 Win=8192 Len=2896 TSval=4294964239 TSecr=1943673918 [TCP PDU reassembled in 25]
22	11.322856473	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=1055 Ack=3289 Win=61440 Len=0 TSval=1943673976 TSecr=4294964239
23	11.323537905	192.168.1.5	192.168.1.3	TCP	1514	80 → 37996 [ACK] Seq=3289 Ack=1055 Win=8192 Len=1448 TSval=4294964239 TSecr=1943673918 [TCP PDU reassembled in 25]
24	11.323594073	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=1055 Ack=4737 Win=68160 Len=0 TSval=1943673977 TSecr=4294964239
25	11.324635201	192.168.1.5	192.168.1.3	HTTP	654	HTTP/1.1 200 OK (text/html)
26	11.324650583	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=1055 Ack=5325 Win=59648 Len=0 TSval=1943673977 TSecr=4294964239
27	11.978661816	192.168.1.3	192.168.1.5	HTTP	544	GET /dvwa/dvwa/css/main.css HTTP/1.1
32	11.991037933	192.168.1.5	192.168.1.3	HTTP	250	HTTP/1.1 304 Not Modified
33	11.991091142	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=1533 Ack=5517 Win=59648 Len=0 TSval=1943674644 TSecr=4294964262
37	11.996088278	192.168.1.3	192.168.1.5	HTTP	602	GET /dvwa/dvwa/images/logo.png HTTP/1.1
38	11.997199608	192.168.1.5	192.168.1.3	HTTP	250	HTTP/1.1 304 Not Modified
39	12.030438049	192.168.1.3	192.168.1.5	TCP	66	37996 → 80 [ACK] Seq=2069 Ack=5710 Win=59648 Len=0 TSval=1943674693 TSecr=4294964262

3. Traffic Analysis & Filtering

To diagnose the network health and security posture, specific filters were applied to the capture file.

Applied Filters:

- icmp: Verified reachability and latency.
- http: Inspected web traffic for unencrypted data.
- tcp.flags.reset == 1: Searched for rejected connection attempts.

TCP Stream Follow:

By selecting a packet and using **Follow > TCP Stream**, the full application-layer conversation was reconstructed.

```
Wireshark - Follow TCP Stream (tcp.stream eq 3) - eth0

POST /dvwa/login.php HTTP/1.1
Host: 192.168.1.5
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 44
Origin: http://192.168.1.5
Connection: keep-alive
Referer: http://192.168.1.5/dvwa/login.php
Cookie: security=high; PHPSESSID=93ac94d45eacc46c37844874811a3017
Upgrade-Insecure-Requests: 1
Priority: u=0, i

username=admin&password=password&Login=Login
HTTP/1.1 302 Found
Date: Mon, 04 May 2026 14:39:57 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Location: index.php
Content-Length: 0
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Content-Type: text/html

GET /dvwa/index.php HTTP/1.1
Host: 192.168.1.5
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.5/dvwa/login.php
Connection: keep-alive
Cookie: security=high; PHPSESSID=93ac94d45eacc46c37844874811a3017
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

4. Command Line Capture (tcpdump)

For lightweight or remote analysis, tcpdump was utilized to capture packets directly to a .pcap file.

Executed Command:

```
sudo tcpdump -i eth0 -w capture.pcap host [Target_IP]
```

```
(kali@Usman)~$ sudo tcpdump -i eth0 -w capture.pcap host 192.168.1.5
[sudo] password for kali:
tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

5. Diagnosis & Security Findings

Security Assessment

- **Sensitive Data Exposure: Critical.** Plaintext credentials were successfully intercepted during a login attempt to the /dvwa/login.php page. The packet analysis revealed the following sensitive information in an unencrypted POST body:
 - **Username:** admin
 - **Password:** password

- **Session ID:** a396e82b7c5c3f292bc3d56cf1e901be (found in the PHPSESSID cookie). Since the traffic is not encrypted, any user on the same network could perform a session hijack or credential theft.
- **Connectivity Health:** The connectivity between the attacker (Kali) and the target (Metasploitable) is stable. The HTTP/1.1 200 OK responses and the subsequent successful loading of the index.php page indicate that there is no significant packet loss, firewall interference, or TCP reset (RST) activity on the observed ports.

Root Cause Analysis

The primary security vulnerability identified is the use of the **unencrypted HTTP protocol (Port 80)** for transmitting authentication data.

Because HTTP lacks Transport Layer Security (TLS), data is sent in **cleartext**. This allows a network sniffer (like Wireshark or tcpdump) to perform a passive Man-in-the-Middle (MitM) attack, reconstructing the entire session and harvesting credentials without the user's knowledge.

6. Recommendations

- **Enforce Encryption (HTTPS):** Transition the web application from HTTP to **HTTPS** by installing an SSL/TLS certificate. This ensures that all data between the browser and the server is encrypted, rendering intercepted packets unreadable.
- **Secure Cookie Attributes:** Implement the Secure and HttpOnly flags on the PHPSESSID cookie. The Secure flag ensures the cookie is only sent over encrypted connections, while HttpOnly prevents client-side scripts from accessing it.
- **Disable Legacy Protocols:** Identify and disable other plaintext management protocols on the host, such as Telnet (Port 23) and FTP (Port 21), replacing them with **SSH** and **SFTP**.
- **Network Hardening:** Implement **Dynamic ARP Inspection (DAI)** and **DHCP Snooping** on the network switches to prevent attackers from using ARP poisoning to redirect traffic into their sniffing tools.